Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

COURSE 3

Remediate threats using Microsoft Defender

Introduction to Microsoft Defender for Office 365

Learn Office 365 specific terminology, threats, and concepts

Microsoft Defender for Office 365 is a cloud-based email filtering service that helps protect your organization against unknown malware and viruses by providing robust zero-day protection. It includes features to safeguard your organization from harmful links in real time. Microsoft Defender for Office 365 has rich reporting and URL trace capabilities that give administrators insight into the kind of attacks happening in your organization.



Microsoft Defender for Office 365 provides the following benefits:

Industry-leading Protection. Microsoft Defender for Office 365 uses 6.5 trillion signals daily from email alone to quickly and accurately detect threats and protect users against sophisticated attacks such as phishing and zero-day

malware. Microsoft Defender for Office 365 blocked 5 billion phish emails and analyzed 300k phish campaigns in 2018 protecting 4 million unique users from advanced threats.

Actionable Insights. Actionable insights are presented to security administrators by correlating signals from a broad range of data to help identify, prioritize, and provide recommendations on how to address potential problems. The recommendations include remediation actions empowering administrators to proactively secure their organization.

Automated response. Investigation and remediation in post-breach scenarios can be difficult, expensive, and time-consuming. Most organizations lack the expertise and resources needed for rapid investigation and effective remediation. Microsoft Defender for Office 365 provides advanced automated response options that security operations can use saving a significant amount of time, money, and resources.

Training & awareness. Social engineering attacks such as phishing often look legitimate and are hard to spot for busy users. It's critical to train end users to make the right decisions in the event of an attack. In-product notifications help users understand the risks of performing an action such as clicking on a suspicious link. Features such as attack simulator help administrators launch realistic threat simulations to train users to be more aware and vigilant. User reporting capabilities empower users to notify Microsoft of suspicious content.

The following are the primary ways you can use Microsoft Defender for Office 365 for message protection:

In a Microsoft Defender for Office 365 filtering-only scenario, Microsoft Defender for Office 365 provides cloud-based email protection for your on-premises Exchange Server environment or any other on-premises SMTP email solution.

Microsoft Defender for Office 365 can be enabled to protect Exchange Online cloud-hosted mailboxes.

In a hybrid deployment, Microsoft Defender for Office 365 can be configured to protect your messaging environment and control mail routing when you have a mix of on-premises and cloud mailboxes with Exchange Online Protection for inbound email filtering.

Automate, investigate, and remediate

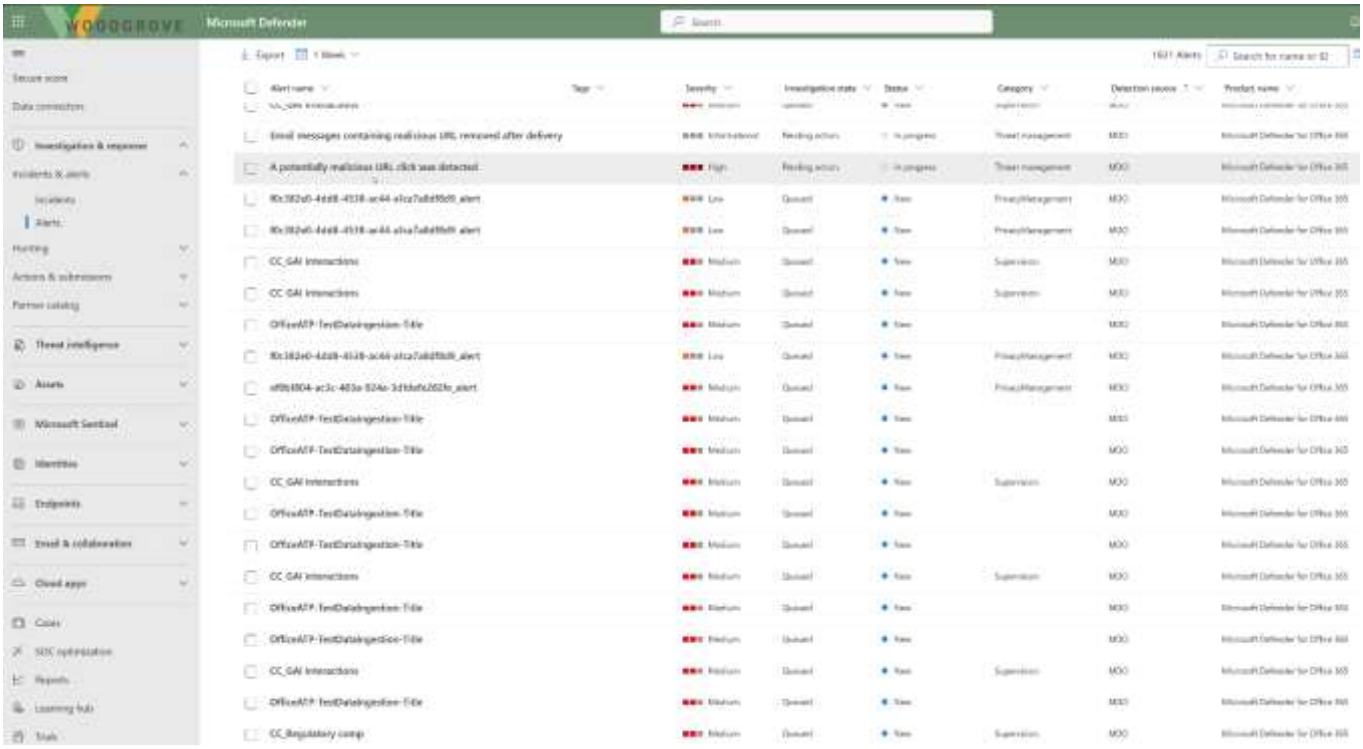
Save time with automated investigation and response

When you're investigating a potential cyberattack, time is of the essence. The sooner you identify and mitigate threats, the better off your organization is. Automated investigation and response (AIR) capabilities include a set of security playbooks that can be launched automatically, such as when an alert is triggered, or manually, such as from a view in Explorer. AIR can save your security operations team time and effort in mitigating threats effectively and efficiently.

At a high level, the AIR flow works like this:

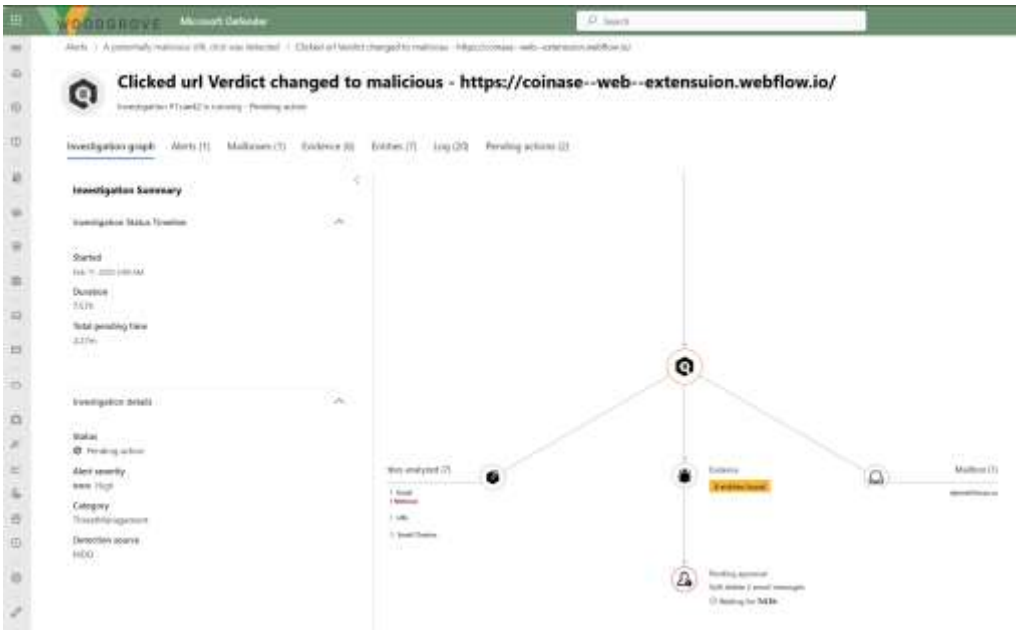
Phase	What's involved
1	An alert that is triggered, and a security playbook initiates.
2	Depending on the particular alert and security playbook, automated investigation begins immediately. (Alternately, a security analyst can start an automated investigation manually, from a value in a report such as Explorer.)
3	While an automated investigation runs, its scope can increase as new, related alerts are triggered.
4	During and after an automated investigation, details and results are available to view. Results include recommended actions that can be taken to respond and remediate any threats that were found. In addition, a playbook log is available that tracks all investigation activity. If your organization is using a custom reporting solution or a third-party solution, you can use the Office 365 Management Activity API to view information about automated investigations and threats.
5	Your security operations team reviews the results and recommendations, and approves remediation actions. In Office 365, remediation actions are taken only upon approval by your organization's security team.

Let's start with a native alert generated by Office 365. These alerts are typically investigated manually today – this process is where AIR comes in. Attackers frequently send through benign URLs in emails to bypass notice from security solutions, then they weaponize them after delivery to activate their attack. Notice in the following screenshot that the alert identifies that a URL that was recently weaponized was detected by Microsoft Defender for Office 365 through Safe Links URL detonation (under Details on the right-hand side).



Microsoft Defender for Office 365 triggered an AIR playbook based on this alert and resolved the alert given the auto investigation having completed.

Selecting the investigation link from the alert brings us into the Microsoft Defender Summary Investigation Graph. The graph shows the evidence, entities: URLs, emails, users (and their activities), and devices that have been automatically investigated as part of the triggered alert. It also shows the relationships between these entities, as shown in the following screenshot:



Specifically:

Emails that were identified as being relevant to this investigation (based on sender, IP, domain, URL, and other email attributes) and a subset of them were identified as being malicious, sent from an internal user in the organization, which itself is a strong indicator of a compromised user.

A user pivot on this investigation also identifies anomalies for one user with respect to a suspicious sign-in and mass downloads of documents.

With the compromised user, user anomalies and compromised device threats identified in this investigation, Microsoft Defender for Office 365 ran auto remediations such as blocking the URL, deleting any emails in mailboxes related to this URL, and triggering the Microsoft Entra workflows for password reset and MFA for the

compromised user. The ability to take automatic action or drive remediations with manual approval, based on policy, are core elements of AIR.

AIR in Microsoft Defender for Office 365 includes certain remediation actions. Whenever an automated investigation is running or has completed, you'll typically see one or more remediation actions that require approval by your security operations team to proceed. Such remediation actions include:

Soft delete email messages or clusters

Block URL (time-of-click)

Turn off external mail forwarding

Turn off delegation

For this alert, these actions can be found in the Pending actions tab under the selected investigation, as shown in the following screenshot:



Configure, protect, and detect

With Microsoft Defender for Office 365, your organization's security team can configure protection by defining policies in the Microsoft Defender portal. The policies that are defined for your organization determine the behavior and protection level for predefined threats. Policy options are flexible. For example, your organization's security team can set fine-grained threat protection at the user, organization, recipient, and domain level. It's important to review your policies regularly because new threats and challenges emerge daily.

Safe Attachments

Microsoft Defender for Office 365 Safe Attachments protects against unknown malware and viruses, and provides zero-day protection to safeguard your messaging system. All messages and attachments that don't have a known virus/malware signature are routed to a special environment where Microsoft Defender for Office 365 uses various machine learning and analysis techniques to detect malicious intent. If no suspicious activity is detected, the message is released for delivery to the mailbox.

When you're creating a Safe Attachments policy, the following options can be selected:

Under the Action for unknown malware in Attachments:

Off. Attachments won't be scanned for malware.

Monitor. Continues delivering the message after malware is detected and track the scanning results.

Block. Blocks the current and future emails and attachments with detected malware.

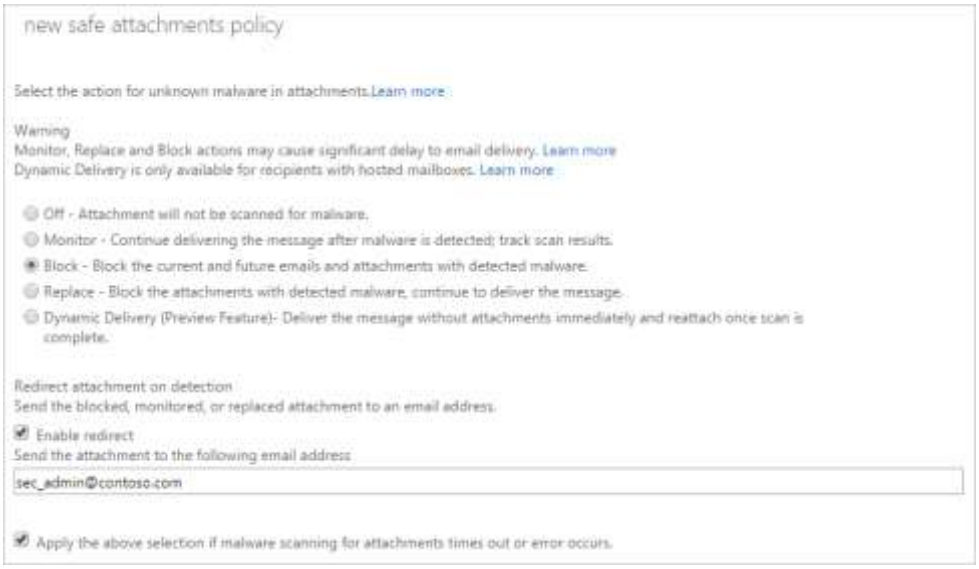
Replace. Blocks the attachments with detected malware but continues to deliver the message body to the user.

Dynamic delivery. Immediately delivers the message body without attachments and reattaches attachments after scanning if they're found to be safe.

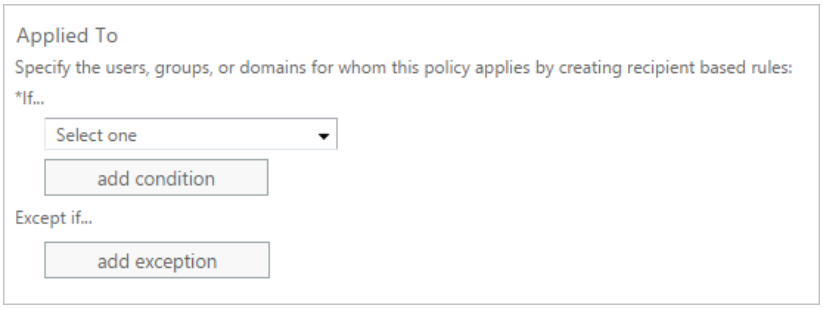
Under Redirect attachment on detection you have the ability to enable one or both of the following settings:

If you want to forward attachments that are blocked, replaced, or monitored to a security administrator in your organization for further investigation, check the Enable redirect checkbox and enter an email address.

You can also have those attachments forwarded if the scanning process should time out by selecting the Apply the above selection if malware scanning for attachments times out or error occurs checkbox.



Once you've configured these settings, you can target users with that policy by specific domain, username, or group membership (or a combination). There are also exceptions that can be configured for this targeting, by users, groups, or domain.



Sometimes it's useful to allow mail to flow without delay from internal senders such as scans or faxes that send attachments that are known to be safe and from a trusted source. It isn't recommended to skip filtering for all internal messages as a compromised account would be able to potentially send malicious content. You can create a transport rule, also known as a mail flow rule, in the Exchange admin center (EAC) to bypass safe attachments scanning. As part of the mail flow rule, modify the message properties to set a message header with the X-MS-Exchange-Organization-SkipSafeAttachmentProcessing as the header name to bypass the safe attachment policy.

Safe Links

The Microsoft Defender for Office 365 Safe Links feature proactively protects your users from malicious URLs in a message or in an Office document. The protection remains every time they select the link, as malicious links are dynamically blocked while good links can be accessed.

Safe Links is available for URLs in the following apps:

Microsoft 365 apps for enterprise on Windows or Mac

Office for the web (Word for the web, Excel for the web, PowerPoint for the web, and OneNote for the web)

Word, Excel, PowerPoint, and Visio on Windows, as well as Office apps on iOS and Android devices

Microsoft Teams channels and chats

Safe links are both client and location agnostic, in that the location and device being used by the end user won't affect the behavior of wrapped links. Additionally, Safe links can be configured to support links in Office 2016 clients where the user is signed in with their Office 365 credential.

Safe links include a default policy that controls global settings such as which links to block and which links to wrap. You can't delete this policy, but you can edit it in your environment as needed, such as blocking a malicious link specific to your environment. It's recommended that you apply Microsoft Defender for Office 365 safe links policies to ALL users in your organization.

The following options can be configured as part of the Safe Links policy:

For Select the action for unknown potentially malicious URLs in messages, selecting On will allow URLs to be rewritten and checked.

Use Safe Attachments to scan downloadable content will enable URL detection to scan files hosted on web sites. For example, if an email contains a link such as https://contoso.com/maliciousfile.pdf, the .pdf file is opened in a separate hypervisor environment and, if the file is found to be malicious, users will see a warning page if they select the link.

Apply safe links to messages sent within the organization will provide the same level of protection when links are sent by email within the organization.

Do not track when users click safe links enables or disables storing Safe Links select data for clicked URLs. Microsoft recommends leaving this setting unselected, which enables tracking for clicked URLs.

Do not allow users to click through to the original URL will prevent users from proceeding to the target web site if it's found to be malicious.

If users frequently receive links from web sites that are known to be safe, you can enter those URLs under Do not rewrite the following URL. For example, you might add the URL to a partner's website if users frequently receive emails from the partner that include URLs to the external organization's website.



Similar to bypassing safe attachments, you can also create a transport rule to bypass safe links. The message header for bypassing safe links is X-MS-Exchange-Organization-SkipSafeLinksProcessing.

Anti-phishing policies

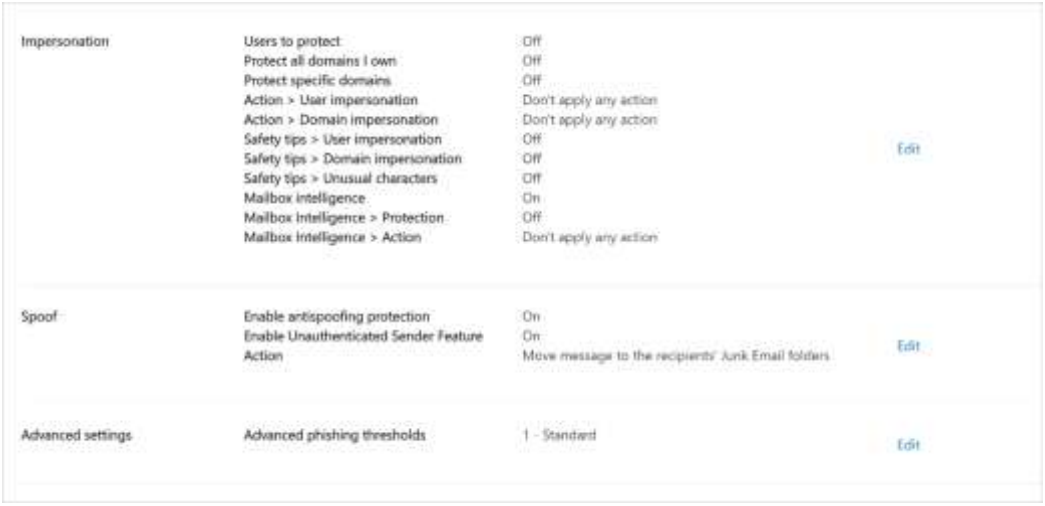
Microsoft Defender for Office 365 anti-phishing checks incoming messages for indicators that a message might be a phishing attempt. When users are covered by Microsoft Defender for Office 365 policies (Safe Attachments, Safe Links, or anti-phishing), incoming messages are evaluated by multiple machine learning models that analyze messages. The appropriate action is taken, based on the configured policies.

There's no default Microsoft Defender for Office 365 anti-phishing policy. When you're creating one, only targeting is originally configured. Impersonation settings play a large role in Microsoft Defender for Office 365 anti-phishing policies. Impersonation is where the sender or the sender's email domain in a message looks similar to a real sender or domain:

An example impersonation of the domain contoso.com is ćóntoso.com.

An example impersonation of the user michelle@contoso.com is michele@contoso.com.

An impersonated domain might otherwise be considered legitimate (registered domain, configured email authentication records, etc.), except its intent is to deceive recipients. In the Microsoft Defender for Office 365 anti-phishing policy, you can configure a set of users to protect, domains to protect, actions for protected users (such as redirect messages or sending to junk folders), safety tips, trusted senders, and domains and more. These settings are exclusive to Microsoft Defender for Office 365 anti-phishing. Anti-spoofing settings are also included in Microsoft Defender for Office 365 anti-phishing policies.



Microsoft Security Copilot Phishing Triage Agent in Microsoft Defender

Phishing remains one of the most common entry points for cyberattacks and a persistent operational burden for security operations center (SOC) teams. Analysts face a continuous stream of user-reported suspicious emails that require careful review and triage. At scale, this volume slows response, consumes analyst time, and increases the risk of genuine threats being missed.

The Phishing Triage Agent in Microsoft Defender is an AI agent that helps security teams scale the triage and classification of user-reported phishing emails, reducing repetitive investigation work and accelerating response.

How the Phishing Triage Agent works

The Phishing Triage Agent is a Security Copilot agent in Microsoft Defender that enhances the efficiency of security operations teams by classifying and triaging user-submitted phishing incidents. The agent uses large language model (LLM)-based analysis to assess reported emails, determine intent, and classify each submission as a real threat or a false positive.

Rather than relying on static rules or predefined inputs, the agent applies contextual reasoning to evaluate submissions dynamically and at scale. By filtering out false alarms, the agent enables analysts to focus on confirmed threats and higher-impact investigations.

Key capabilities

The agent's key capabilities include:

Autonomous triage: Uses advanced AI tools to perform sophisticated assessments and determine whether a submission is a real threat or a false alarm, without requiring step-by-step human input or code.

Transparent rationale: Provides transparent rationale for its classification verdicts in natural language, detailing the reasoning behind its conclusions and the evidence used to reach them. It also provides a visual representation of its reasoning process.

Learning based on feedback: Analysts can provide feedback on classification outcomes. Over time, this feedback helps refine the agent's behavior to better reflect organizational context and reduce manual follow-up.

Security tools and detection capabilities

To investigate phishing attempts, the agent uses a combination of Microsoft Defender and Microsoft Security Copilot capabilities, along with a set of security tools that continuously evolve as new detection techniques and integrations become available:

Email content analysis: Detects suspicious patterns and indicators in email bodies

File and URL detonation: Safely executes and analyzes potentially malicious files and links using Microsoft deep analysis tools

Screenshot analysis: Reviews visual content from emails, URLs, and supported file types

Threat intelligence tools: Uses Microsoft Threat Intelligence feeds to provide enriched detection context

Advanced hunting across data sources: Correlates signals across all available security data sources to contextualize suspicious activity and drive informed investigative decisions

Prerequisites and requirements

To run the Phishing Triage Agent in your environment, you need:

Products

Security Copilot: Provisioned capacity in Security Compute Units (SCU)

Microsoft Defender for Office 365 Plan 2: Must be deployed

Microsoft Defender required features

Unified role-based access control (URBAC): Must be enabled for Defender for Office 365

Activate the Defender for Office 365 workload in the Microsoft Defender XDR settings

User reported settings: Enable "Monitor reported messages in Outlook" to define how users report potentially malicious messages

Select any of the "Reported message destinations" options

If using a third-party email reporting tool, review options for integration with Microsoft Defender XDR

Alert policy: Ensure the alert policy "Email reported by user as malware or phish" is turned on

The agent doesn't classify alerts suppressed by alert tuning

Disable the "Auto-Resolve - Email reported by user as malware or phish" built-in alert tuning rule

Plugins

The Phishing Triage Agent automatically activates these Security Copilot plugins:

Microsoft Defender XDR

Microsoft Threat Intelligence

Phishing Triage Agent

Permissions required

The agent identity needs these permissions to access emails, analyze their content, and manage alerts:

Security data basics (read): Access basic security data, such as alerts and incidents

Alerts (manage): Classify the alert and monitor the alert's state

Security Copilot (read): Access Security Copilot capabilities

Email & collaboration metadata (read): Access metadata for user reported emails

Email & collaboration content (read): Read the content of user reported emails needed for analysis

These permissions are under the Security operations permissions group and must be scoped to the Microsoft Defender for Office 365 data source.

Set up the Phishing Triage Agent

The setup process involves assigning the agent an identity and the required permissions. You can open the Phishing Triage Agent setup wizard in one of two ways:

From the Security Store in the Microsoft Defender portal

From the Incidents queue in the Microsoft Defender portal, select Set up agent

Assign the agent's identity

The agent requires an identity to operate. You can select one of two identity types:

Create a new agent identity (recommended): Automatically create a new Microsoft Entra Agent ID. Microsoft Entra creates Agent IDs specifically for AI agents. Using Agent IDs keeps access scoped, secure, and easier to manage.

Connect an existing user account: Assign an existing user account as the agent identity. The agent inherits the user account's access and permissions.

When using this option, set a long account expiration date and closely monitor authentication status

The agent's user identity isn't compatible with PIM or TAP

Tip

Use a dedicated identity account with the minimum required permissions for the agent. Assign a distinct display name like "Phishing Triage Agent" to easily identify it in the Microsoft Defender portal.

Assign permissions

In alignment with the principle of least privileges, assign the agent identity only the permissions the Phishing Triage Agent requires to perform its tasks:

If you use an Agent ID, the dropdown only displays roles with the required permissions

If you use an existing user account, you must assign the required permissions to that identity before setup

Important

After assigning the agent its permissions, ensure the user group monitoring the agent has equal or higher permissions to oversee its activity and output.

Enhance incident response

The Phishing Triage Agent is designed to help security teams manage the overwhelming volume of suspicious emails organizations receive daily. Acting as a force multiplier for SOC teams, the agent offloads time-consuming triage tasks, reduces alert fatigue, and accelerates incident response.

Agent trigger and workflow

Once fully set up and running, the Phishing Triage Agent is automatically triggered when a user reports a suspicious phishing email and an alert is created. The agent then autonomously analyzes the alert using sophisticated AI tools and your organization's context.

Classification outcomes:

False Positive: If the alert is determined to be a false alarm, the agent classifies it and resolves it accordingly

True Positive: If the alert is deemed malicious, it's classified as such, and the status of the associated incident remains open and in progress for an analyst to investigate

For every alert it processes, the agent provides a detailed explanation of its verdict, enhancing transparency and building analyst confidence.

Collaborate with the agent

To maintain transparency, the agent routinely updates incident fields during the triage process:

When triaging starts, the agent assigns the alert to itself

Adds an "Agent" tag to the corresponding incident

Analysts can filter the incident queue to see only incidents tagged by the agent

When an alert is identified as a true phishing threat, the Phishing Triage Agent marks it as a True Positive, enabling analysts to prioritize confirmed threats and respond more swiftly. This results in significant queue reduction and minimizes time spent sorting through false positives.

Transparency and explainability

The Phishing Triage Agent is purpose-built to clearly explain why and how it made each decision. For every alert it processes, it provides:

A detailed explanation in plain text

A full graphical representation of its decision-making workflow

This transparency allows analysts to quickly interpret results, build trust in the agent's output, and focus their time on making informed decisions.

To review the agent's findings:

Select an incident from the incident queue

Look for the Phishing Triage Agent card in the Copilot or Tasks side panel under the Guided Response Triage section

The card presents the agent's verdict based on its classification, highlighting key pieces of incriminating evidence

Select View agent activity to see the steps the agent took prior to reaching its classification

Teach the agent through feedback

The Phishing Triage Agent continuously improves its decision-making based on feedback tailored to your organization's needs. Analysts can provide input in plain, natural language, making it easy to guide and shape the agent's behavior.

Provide feedback

To provide feedback and teach the agent:

In the incident page, locate the Phishing Triage Agent card

Review the agent's classification and reasoning

If the decision doesn't align with your organization's classification criteria, select Change classification

In the Manage alert pane, select the new classification and provide your reason for the change

Select Use this feedback to teach the agent to apply your feedback

Choose Evaluate feedback to preview how the agent translates your feedback into a lesson

If the result meets your expectations, select Save to store it as a lesson in the agent's memory

Note

You can only provide feedback to the agent once per alert, and it can only be used to teach the agent how to classify phishing alerts. Always review your feedback before saving the lesson.

Best practices for writing feedback

To ensure the agent effectively incorporates your feedback:

Ensure feedback is relevant and contextual: Feedback should pertain only to the email currently under review and align with the updated classification

Be descriptive and specific: Clearly explain characteristics like email subject, message body, sender, or recipients

Ensure clarity and decisiveness: Avoid vague or universal statements. Use clear and actionable terms

Be consistent with previous feedback: Ensure new feedback aligns with previously provided input

Review the agent's interpretation: Always verify that the feedback is accurately translated into a lesson

Monitor and manage the agent

You can view agent metrics and manage the agent from the Phishing Triage Agent page:

Navigate to Security Copilot > Agents, look for the Phishing Triage Agent under Agents in use, and select Go to agent

Overview tab

The Overview tab provides:

Details about the agent's current status, identity, role, and recent activity

A list of recent activities with the ability to view investigation details and full workflow

Performance tab

The Performance tab displays key metrics including:

Daily activity

Mean time to triage (MTTT)

SCU consumption

Management options

From the agent page, you can:

Pause or Run: Temporarily stop or restart the agent's activities

Change identity and role: Edit the agent's identity and permissions

View and manage feedback: Access the Agent feedback page to review all submitted feedback

Remove the agent: Stop triage and classification of new incidents (all feedback is deleted, but history is retained)

Key benefits

The Phishing Triage Agent delivers several important benefits:

Reduces manual workload: Automates the time-consuming process of triaging user-reported phishing emails

Improves efficiency: Filters out false alarms so analysts can focus on confirmed threats

Accelerates response times: Autonomous triage means faster identification and classification of real threats

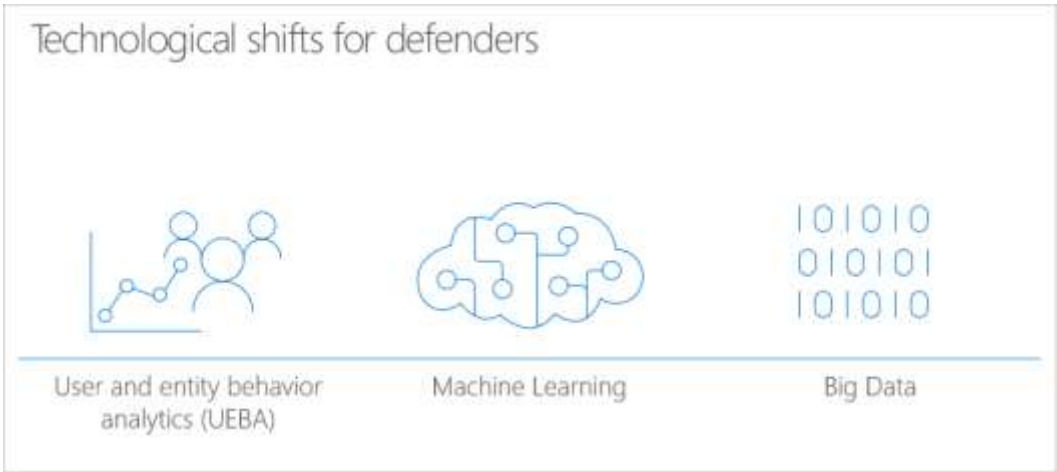
Enhances accuracy: AI-powered analysis combined with organizational feedback improves detection precision over time

Provides transparency: Clear explanations and visual workflows build confidence in agent decisions

Scales with your organization: Handles high volumes of reported emails without requiring other analyst resources

By reducing the burden of reactive work, the Phishing Triage Agent empowers analysts to focus on proactive security measures, ultimately strengthening the organization's overall security posture

Simulate attacks



Microsoft Defender for Office 365 includes best-of-class threat investigation and response tools that enable your organization's security team to anticipate, understand, and prevent malicious attacks.

Note

The following capabilities are now found in Microsoft Defender XDR (Extended Detection and Response) which includes Microsoft Defender for Office 365, Microsoft Defender for Endpoint, and Microsoft Defender for Identity. Microsoft Defender XDR provides a unified view of threats across your organization, and enables you to investigate and respond to threats across your Microsoft 365 environment.

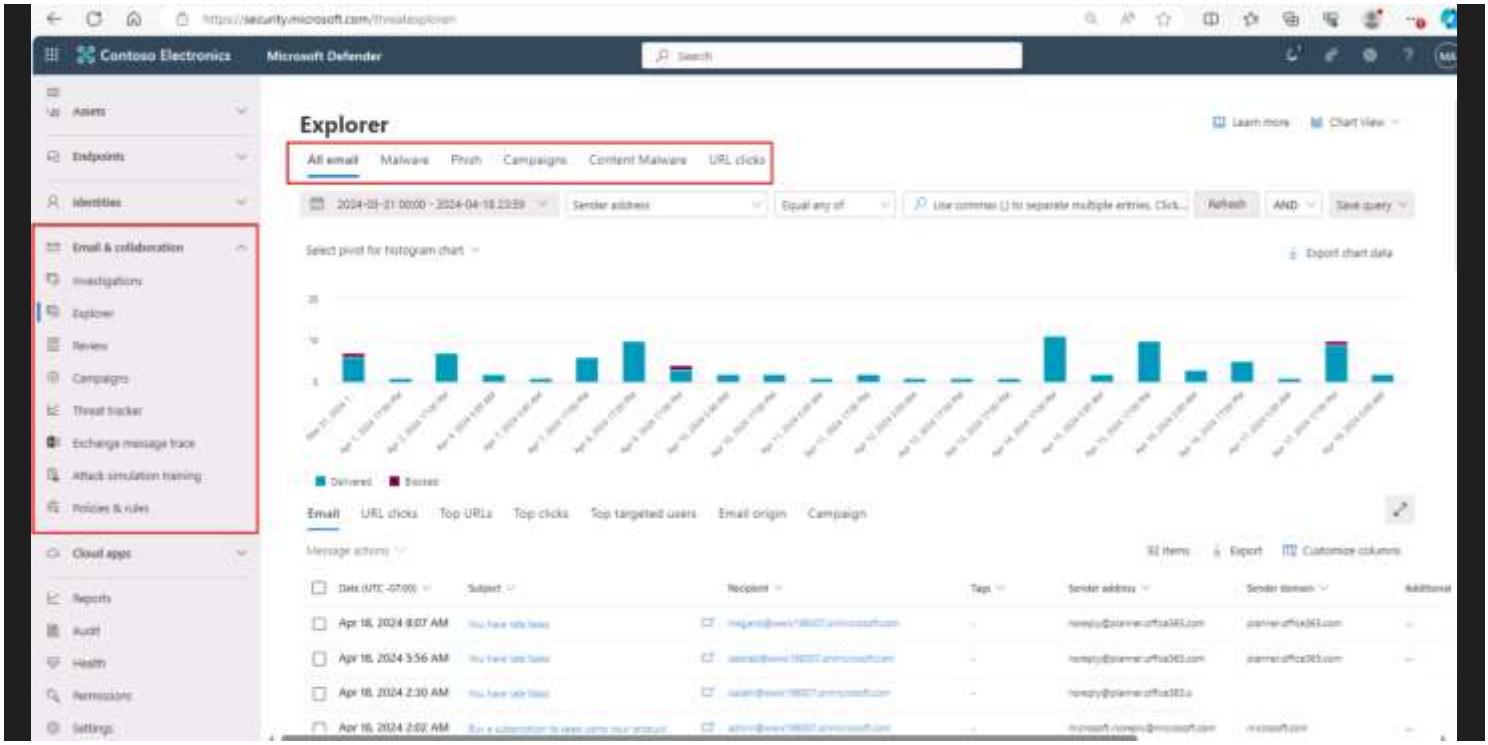
Threat trackers provide the latest intelligence on prevailing cybersecurity issues. For example, you can view information about the latest malware, and take countermeasures before it becomes an actual threat to your organization. Available trackers include Noteworthy trackers, Trending trackers, Tracked queries, and Saved queries.

Threat Explorer (or real-time detections) (also referred to as Explorer) is a real-time report that allows you to identify and analyze recent threats. You can configure Explorer to show data for custom periods.

Attack Simulator allows you to run realistic attack scenarios in your organization to identify vulnerabilities. Simulations of current types of attacks are available, including spear phishing, credential harvest and attachment attacks, and password spray and brute force password attacks.

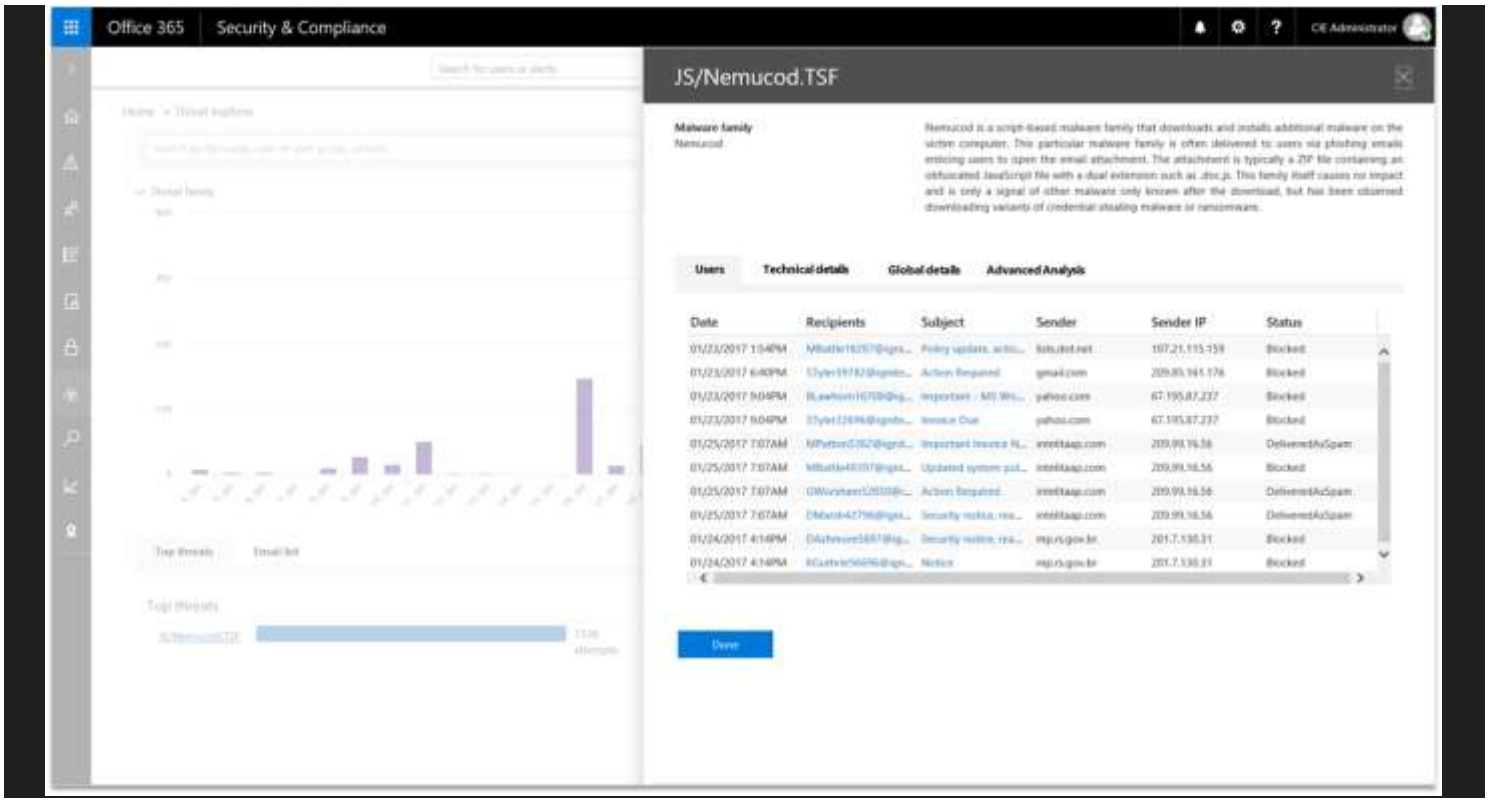
Threat Explorer enables you to begin delving into granular data for your organization. Inside Threat Explorer, you're first shown the variety of threat families impacting our organization over time. Additionally, you're shown the top threats and top targeted users inside the organization.

You can also change the category for the graph. In this case, All email is shown, and you can filter the Threat Explorer graph on many options including the Sender address, Recipients, and even the detection technology used to stop a threat. The Detection technology identifies if an email is blocked by Microsoft Defender for Cloud's sandboxing or through an Exchange Online Protection (EOP) filter. The graph adjusts to reflect the category being examined.



Threat Explorer allows a deeper look into a threat, beginning with a thorough description of this malware family's behavior. Threat Explorer provides a definition of the threat, the message traces of emails delivering the threat, technical details of the threat, global details of the threat, and advanced analysis.

On the Top targeted users tab, you could see each instance that a user in the organization was sent an attachment containing a malware threat. You can not only see the specific recipients and subject, but the sender domain and the sender IP as well. The Delivery action column tells you if the email was caught and blocked before it ever reached the user, or if it was delivered as spam.



If a user received and opened the email that would also appear under Status enabling you to reach out to the user and take the appropriate remediation steps, such as scanning their device.